ТУСУР
TUSUR UNIVERSITY

Безопасность, связанная с персоналом

Управление информационной безопасностью. Лекция 2.3

7 Безопасность, связанная с персоналом

Раздел включает в себя 3 категории и 6 мер обеспечения информационной безопасности:

7.1 При приеме на работу
Цель: Обеспечить уверенность в том, что работники и подрядчики понимают свои обязанности и подходят для роли, на которую они рассматриваются.

- 7.1.1 Проверка
- 7.1.2 Правила и условия работы

7.2 Во время работы
Цель: Обеспечить уверенность в том, что работники и подрядчики осведомлены о своих обязанностях в отношении ИБ и выполняют их.

- 7.2.1 Обязанности руководства организации
- 7.2.2 Осведомленность, обучение и практическая подготовка (тренинги) в области информационной безопасности
- 7.2.3 Дисциплинарный процесс

7.3 Увольнение и смена места работы
Цель: Защита интересов организации при смене места работы или увольнении работника.

- 7.3.1 Прекращение или изменение трудовых обязанностей

Проверка

Проверка всех кандидатов при приеме на работу должна осуществляться согласно соответствующим законам, правилам и этическим нормам и должна быть соразмерна требованиям бизнеса, категории информации, которая будет доступна, и предполагаемым рискам ИБ.

Проверку следует проводить принимая во внимание обеспечение конфиденциальности, защиту персональных данных и законодательство о трудоустройстве, и там, где это разрешено, она должна включать в себя следующее:

a) наличие удовлетворительных характеристик, например одной от организации и одной от физического лица;
b) проверку (на полноту и точность) биографии заявителя;
c) подтверждение заявленного образования и профессиональной квалификации;
d) независимую проверку личности (паспорт или иной подобный документ);
e) более детальную проверку, такую как обзор кредитной истории или проверку судимостей.

В случаях, когда работнику после приема на работу или при продвижении по службе предоставляется обязательный доступ к конфиденциальной информации, и, в частности, обрабатывающим конфиденциальную информацию, например финансовую или секретную, организации следует проводить дальнейшие, более детальные, проверки.

Проверка

Процесс проверки также следует обеспечивать в отношении подрядчиков. В этих случаях в соглашении между сторонами должны быть четко указаны обязанности по проведению проверки и процедуры уведомлений, которые необходимо соблюдать, если проверка не была завершена или если результаты дают основания для сомнений или опасений.

Правила и условия работы

В договорных соглашениях с работниками и подрядчиками должны быть установлены их обязанности и обязанности организации по обеспечению ИБ.

Договорные обязательства для работников и подрядчиков должны отражать политики организации в области ИБ, дополнительно уточняя и утверждая:

a) что все работники и подрядчики, которым предоставляется доступ к конфиденциальной информации, должны подписать соглашение о конфиденциальности или неразглашении до получения доступа к средствам обработки информации;
b) юридическую ответственность и права работника или подрядчика, например в отношении законов об авторском праве или защите данных;
c) обязанности по категорированию информации и управлению информацией организации, иными активами, связанными с информацией, средствами ее обработки и информационными системами, используемыми работником или подрядчиком;
d) ответственность работника или подрядчика за обработку информации, полученной от других компаний или внешних сторон;
e) действия, которые необходимо предпринять, если работник или подрядчик не соблюдает требования безопасности организации.

Правила и условия работы

Роли и обязанности в области ИБ должны быть доведены до сведения кандидатов до их приема на работу.

Организация должна обеспечивать уверенность в том, что работники и подрядчики согласны с условиями, касающимися ИБ, соответствующими характеру и уровню доступа, который они будут иметь к активам организации, связанным с информационными системами и сервисами.

Там, где это применимо, действие обязанностей, содержащихся в правилах и условиях работы, должно быть продлено на определенный период после прекращения трудовых или договорных отношений.

Обязанности руководства организации

Руководство организации должно требовать от всех работников и подрядчиков соблюдения ИБ в соответствии с установленными в организации политиками и процедурами.

В обязанности руководства входит обеспечение того, чтобы работники и подрядчики:

a) были надлежащим образом проинформированы об их ролях и обязанностях в области ИБ до предоставления доступа к конфиденциальной информации или информационным системам;
b) были обеспечены рекомендациями, которые устанавливают ожидания по ИБ для их роли в организации;
c) были мотивированы выполнять политики ИБ организации;
d) были осведомлены об ИБ настолько, насколько это предполагают их роли и обязанности в организации;
e) соблюдали правила и условия работы, в том числе политику ИБ организации и соответствующие методы работы;
f) поддерживали соответствующий уровень навыков и квалификацию, а также регулярно проходили обучение;
g) имели канал для анонимного сообщения о нарушениях политик или процедур ИБ ("информирование о нарушениях").

Руководство должно демонстрировать поддержку политик, процедур и мер обеспечения ИБ и выступать в качестве образца для подражания.

Обязанности руководства организации

Если работники и подрядчики не осведомлены о своих обязанностях в области ИБ, то они могут нанести значительный ущерб организации. Гораздо надежнее иметь мотивированный персонал, который, вероятно, будет вызывать меньше инцидентов ИБ.

Недостаточное управление может привести к тому, что персонал будет чувствовать себя недооцененным, что может привести к негативному влиянию на ИБ в организации. Например, плохое управление может привести к игнорированию требований ИБ или возможному неприемлемому использованию активов организации.

Осведомленность, обучение и практическая подготовка в области информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Все работники организации и при необходимости подрядчики должны быть надлежащим образом обучены, практически подготовлены и на регулярной основе осведомлены об обновлениях политик и процедур ИБ организации, необходимых для выполнения их функциональных обязанностей.

Программа повышения осведомленности в области ИБ должна быть направлена на то, чтобы работники и, в соответствующих случаях, подрядчики понимали свои обязанности по обеспечению ИБ и средства, с помощью которых эти обязанности следует выполнять.

Программа повышения осведомленности в области ИБ должна быть разработана в соответствии с политикой и соответствующими процедурами ИБ организации, принимая во внимание информацию и меры обеспечения ИБ, которые внедрены для ее защиты. Программа должна включать в себя ряд мероприятий, таких как кампании по повышению осведомленности (например, "День информационной безопасности") и выпуск буклетов или информационных бюллетеней.

Осведомленность, обучение и практическая подготовка в области информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Программу повышения осведомленности необходимо планировать с учетом роли работников в организации и, при необходимости, ожиданий организации в отношении осведомленности подрядчиков. Мероприятия в рамках программы должны быть рассчитаны на длительный период, предпочтительно быть регулярными, повторяться и охватывать новых работников и подрядчиков. Следует регулярно обновлять программу, чтобы она соответствовала политикам и процедурам организации и основывалась на уроках, извлеченных из инцидентов ИБ.

Вводный курс следует проходить не только новым работникам, но и тем, кто переводится на новую должность или получает роль с существенно отличающимися требованиями ИБ, при этом обучение следует проводить заранее.

Для большей результативности организация должна разработать программу обучения и практической подготовки. Программа должна соответствовать политике ИБ организации и соответствующим процедурам, принимая во внимание защищаемую информацию и меры, которые были внедрены для обеспечения ее защиты. Программа должна учитывать возможность реализации различных форм обучения и подготовки, например лекции или самостоятельные занятия.

Осведомленность, обучение и практическая подготовка в области информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Обучение и практическая подготовка в области ИБ должна также охватывать общие аспекты, такие как:

a) заявление руководства о приверженности ИБ во всей организации;
b) необходимость ознакомления с правилами и обязательствами, применяемыми в области ИБ, определенными в политиках, стандартах, законах, положениях, договорах и соглашениях;
c) персональная ответственность за свои действия и бездействие, а также общая ответственность за обеспечение безопасности или защиту информации, принадлежащей организации и внешним сторонам;
d) базовые процедуры ИБ (такие как сообщение об инцидентах ИБ) и базовые меры обеспечения ИБ (такие как парольная защита, защита от вредоносного программного обеспечения или "чистый стол");
e) контакты и ресурсы для получения дополнительной информации и консультаций по вопросам ИБ, включая дополнительные материалы по обучению и подготовке в области ИБ.

Дисциплинарный процесс

Должен существовать формализованный и доведенный до персонала дисциплинарный процесс по принятию мер в отношении работников, совершивших нарушение ИБ.

Дисциплинарный процесс не должен быть инициирован, пока не будет уверенности в том, что нарушение ИБ действительно имело место.

Формальный дисциплинарный процесс должен обеспечивать корректное и справедливое обращение с работниками, которые подозреваются в совершении нарушений ИБ. Формальный дисциплинарный процесс должен предусматриваться как соответствующий ответ, учитывающий такие факторы, как характер и серьезность нарушения и его влияние на бизнес, первое это нарушение или повторное, проходил ли нарушитель надлежащее обучение, соответствующее законодательство, бизнес-контракты и другие необходимые факторы.

Дисциплинарный процесс должен использоваться в качестве сдерживающего фактора для предотвращения нарушения работниками как политик и процедур ИБ. Работник обязан соблюдать политику информационной безопасности. *При несоблюдении политики информационной безопасности работодатель вправе обратиться в правоохранительные органы.*

Дисциплинарный процесс также может стать мотивацией или стимулом, если будут определены меры поощрения в случае образцового выполнения требований ИБ.

Прекращение или изменение трудовых обязанностей

Ответственность и обязанности, относящиеся к ИБ, которые сохраняются после увольнения или смены места работы, должны быть определены, доведены до сведения работника или подрядчика и оформлены юридически.

Сообщение об увольнении должно включать в себя текущие требования ИБ и юридические обязательства и, где это применимо, обязательства, содержащиеся в соглашениях о конфиденциальности, а также в правилах и условиях работы, сохраняющие свою силу в течение определенного периода времени после окончания работы работника или подрядчика.

Ответственность и обязанности, которые остаются в силе после увольнения, должны быть закреплены в правилах и условиях работы работника или подрядчика. Изменение должностных обязанностей или функций следует проводить так же, как и в случае с увольнением, при этом дополнив возложением новых должностных обязанностей и функций.

Работников и подрядчиков необходимо информировать об изменениях в штате и порядке работы.

Рассмотренные вопросы

Безопасность, связанная с персоналом:

- При приеме на работу
- Во время работы
- При увольнении

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!